Access Control and Identity and Access Management (IAM) Policy

Policy ID: POL-IAM-009 | Version 1.0 | Classification: Internal

Policy Owner	CISO / Chief Information Officer	**Effective Date**	12 September 2026
Review Cycle	At least annually and upon material legal, threat, technology, or business change	**Approval Authority**	Executive Risk / Information Security Governance Committee
Applies To	Enterprise workforce, controlled entities, and in-scope suppliers	**Control Status**	Mandatory unless formally excepted

Mandatory language: "MUST" and "MUST NOT" indicate mandatory requirements. "SHOULD" indicates an expected control that may be varied only when a risk-based alternative is documented. "Strictly Prohibited" identifies conduct that is not permitted absent an explicit, legally valid emergency or exception pathway.

1. Objective

This policy establishes mandatory rules for digital identity, authentication, authorization, privileged access, service identities, access reviews, joiner-mover-leaver processes, and segregation of duties. Access is granted on least privilege, need-to-know, and explicit accountability principles and must be removed when no longer required.

2. Scope

This policy applies to workforce identities, contractors, partners, customers where enterprise IAM controls apply, service accounts, workloads, bots, API clients, cloud identities, privileged accounts, databases, network devices, applications, SaaS, source repositories, CI/CD platforms, and physical/logical administrative systems.

3. Governance, Accountability, and Roles

IAM Team. Operates directories, SSO, MFA, lifecycle automation, access governance, and privileged access tooling.

Managers. Approve access based on job responsibilities and promptly report role changes.

System/Data Owners. Define roles, approve privileged/sensitive access, and perform periodic reviews.

Security. Defines authentication standards, monitors risky access, and approves exceptions.

Users. Protect credentials, use only assigned accounts, and report suspicious authentication events.

4. Policy Rules and Mandatory Guidelines

- Every human user MUST have a unique identity. Shared named-user accounts are prohibited except controlled technical cases that cannot support individual accounts and require compensating accountability controls.
- Access MUST be granted through approved roles/groups whenever possible rather than direct ad hoc permissions. Permissions MUST align to job function and data classification.
- MFA is Mandatory for remote access, cloud administration, privileged access, source-code platforms, production systems, and other high-risk services. Phishing-resistant methods SHOULD be used for privileged and high-risk identities.
- New privileged access MUST be time-bounded or just-in-time where the platform supports it. Standing global/tenant administrator access is prohibited for routine user accounts.
- Privileged users MUST maintain separate standard and administrative identities where practical. Administrative credentials MUST NOT be used for email, web browsing, or routine collaboration.

- Joiner access MUST be approved and provisioned through the formal workflow. Leaver access MUST be disabled promptly based on HR/vendor termination triggers. High-risk involuntary terminations require coordinated immediate revocation.
- Role changes MUST trigger review/removal of no-longer-required access. Access accumulation across multiple roles without review is prohibited.
- Sensitive and privileged access MUST be recertified periodically by accountable owners. Reviewers MUST actively validate need; rubber-stamp approval is prohibited.
- Credentials MUST NOT be shared, emailed, placed in tickets/chat, reused between personal and enterprise services, or stored in plaintext files.
- Service accounts MUST have a named owner, defined purpose, least privilege, non-interactive login restriction where possible, credential rotation, and lifecycle review. Orphaned service accounts are prohibited.
- Segregation of duties MUST be enforced for materially conflicting activities, such as code approval vs. production release where risk requires separation, payment creation vs. approval, and key administration vs. protected-data administration.
- Emergency break-glass access MUST be limited, strongly authenticated, vaulted, monitored, and reviewed after each use. Break-glass accounts MUST NOT become routine operational accounts.

5. Technical and Coding Constraints

- Authentication systems MUST use modern federation protocols such as SAML 2.0 or OpenID Connect/OAuth 2.0 as appropriate and MUST validate issuer, audience, signature, expiration, and redirect restrictions.
- Passwords, where used, MUST be protected using approved adaptive password hashing. MD5, SHA-1, unsalted fast hashes, reversible encryption, and plaintext password storage are prohibited.
- Applications MUST perform authorization server-side and deny by default. UI hiding, route naming, client-provided role fields, or possession of object identifiers are not valid authorization mechanisms.
- Privileged Access Management (PAM) SHOULD broker high-risk administrator sessions, provide credential vaulting/rotation, and record session metadata or sessions according to legal/privacy constraints.
- Machine-to-machine access SHOULD use short-lived tokens, workload identity, managed identities, mTLS, or signed assertions rather than static long-lived secrets.
- API tokens and service credentials MUST be scoped, stored in approved secret managers, rotated according to risk, and revoked when unused. Tokens with no expiration require specific technical justification.
- Authentication and privilege events MUST be logged, including successful/failed login, MFA changes, password reset, account creation/disablement, role changes, privilege elevation, and break-glass use.
- Conditional access SHOULD evaluate device compliance, location/risk signals, authentication strength, and application sensitivity, while avoiding unjustified exclusion or discriminatory profiling.

6. Operational Control Requirements

- High-risk access reviews MUST occur at least quarterly unless a stricter regulatory/contractual requirement applies. Other sensitive access SHOULD be reviewed at least semiannually or annually based on risk.
- IAM systems MUST support prompt token/session revocation for compromised identities. Security may force reauthentication and credential reset when credible compromise indicators exist.
- Dormant accounts and unused service identities MUST be disabled or removed according to defined inactivity thresholds and business-owner validation.

7. Monitoring, Assurance, and Records

Compliance with this policy MUST be demonstrable. Evidence is part of the control, not an optional administrative artifact. Records MUST be retained according to the enterprise records-retention schedule, legal holds, applicable

regulation, and contractual requirements.

Minimum expected records:

- Identity inventory
- Access requests/approvals
- Access review evidence
- MFA/conditional-access policy
- PAM logs
- Service-account register
- Joiner-mover-leaver audit logs
- Break-glass reviews

Security, Internal Audit, Privacy, Legal, Compliance, and authorized risk functions MAY request evidence and perform sampling or technical validation. System owners MUST provide accurate evidence and MUST NOT suppress, alter, or fabricate control records.

8. Enforcement and Violation Consequences

Unauthorized access may be immediately revoked. Policy violations may result in suspension of accounts, removal of privileged roles, mandatory investigation, disciplinary action, supplier remedies, or legal action. Credential sharing, unauthorized privilege escalation, and deliberate bypass of access reviews are serious violations.

Where a violation creates active risk, protective action may occur before disciplinary or contractual review is complete. Enforcement decisions will consider intent, recurrence, severity, impact, legal duties, and whether the individual promptly reported the issue and cooperated with remediation.

9. Exceptions and Risk Acceptance

IAM exceptions MUST identify account/system, required privilege, business justification, compensating controls, owner, Security approval, and expiration. Exceptions granting persistent global administrator or bypassing MFA require CISO delegate approval and enhanced monitoring.

An exception MUST NOT be interpreted as permanent policy change. The control owner may require additional monitoring, narrower scope, remediation milestones, or earlier review. Expired exceptions automatically cease to authorize the deviation.

10. Standards and Regulatory Alignment

This policy is designed to support the enterprise ISMS and cybersecurity risk program. Mappings are implementation aids; they do not replace a formal applicability analysis, legal advice, or the authoritative standards and regulations.

Framework	Policy alignment
ISO/IEC 27001:2022	Supports identity management, authentication information, access rights, privileged access, segregation of duties, logging, and lifecycle control objectives.
NIST CSF 2.0	PR.AA identity management, authentication and access control; GV.RR responsibilities; DE.CM monitoring; RS.MI containment of compromised identities.
GDPR	Articles 5(1)(f), 25 and 32 support need-to-know access, confidentiality, and security of personal data.

Authoritative reference set

- ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements. This policy supports the ISMS risk-management model and applicable Annex A controls without reproducing proprietary standard text.

- NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (2024). Control outcomes are organized across GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER as applicable.
- Regulation (EU) 2016/679 (General Data Protection Regulation, GDPR), including the principles of Article 5 and, where applicable, Articles 6, 25, 28, 30, 32, 33, 34, 35, and Chapter V on international transfers.

11. Review, Maintenance, and Approval

The policy owner MUST review this document at least annually and whenever a material incident, audit finding, law/regulation, technology change, threat development, merger/acquisition, or operating-model change may affect its adequacy. Proposed changes MUST be version-controlled and approved through the enterprise policy governance process. Local procedures may impose stricter requirements but MUST NOT weaken this policy without an approved exception.

End of controlled document.